

Integrate Zscaler with Identity Providers (IdPs) such as Azure, Okta, and Active Directory for seamless authentication and authorization.

TEAM MEMBERS DETAILS

TEAM NO: 5

TEAM ID: 69a67a29f713ea4f3da53486

TEAM LEADER: ROSHINI S

COLLEGE NAME: Rathinam College of liberal arts and science @tips global

COLLEGE CODE: CD

List of teammates:

S no	Name	College	Contact
1	ROSHINI S	Rathinam College of liberal arts and science @tips global	roshinirosh089@gmail.com
2	SABARI M	Rathinam College of liberal arts and science @tips global	sabaricr9@gmail.com
3	RITHICK G	Rathinam College of liberal arts and science @tips global	rithickrithuu25@gmail.com
4	SARNESH S	Rathinam College of liberal arts and science @tips global	sarneshsarnu@gmail.com
5	MONESH SAI R	Rathinam College of liberal arts and science @tips global	moneshsai328@gmail.com

ABSTRACT:

The integration of Zscaler with Identity Providers (IdPs) such as Microsoft Azure Active Directory, Okta, and Active Directory plays a crucial role in enabling secure and seamless authentication and authorization in modern cloud-based environments. As organizations increasingly adopt cloud applications and remote work models, traditional network security approaches become less effective. Integrating Zscaler with trusted identity providers helps implement a Zero Trust security model, ensuring that only authenticated and authorized users can access organizational resources.

This integration allows users to securely access applications and services through Single Sign-On (SSO), reducing the need for multiple credentials while improving user experience. By leveraging identity-based access control, Zscaler can enforce security policies based on user identity, device posture, and location. Protocols such as SAML (Security Assertion Markup Language) and OAuth are commonly used to establish secure communication between Zscaler and the identity providers.

Furthermore, integrating Zscaler with identity platforms enhances visibility, centralized identity management, and stronger protection against unauthorized access and cyber threats. It enables organizations to maintain consistent security policies across on-premises and cloud environments while simplifying user authentication processes. Overall, this integration improves network security, strengthens access control, and supports secure digital transformation for modern enterprises.

USE CASE SCENARIOS:

1. Single Sign-On (SSO) for Secure Application Access

Use Case Scenario:

An employee logs into the organization's network using their credentials stored in Microsoft Azure Active Directory. When they try to access a cloud application through Zscaler, the authentication request is redirected to Azure AD for verification. Once authenticated, the user gains access without logging in again.

Output:

User is authenticated once and gains seamless access to multiple applications.
Improved user experience and reduced password fatigue.

2. Remote Employee Secure Access

Use Case Scenario:

A remote employee working from home connects to the internet and attempts to access company resources through Zscaler. The system verifies the user's identity through Okta before granting access.

Output:

Only verified users can access company applications from remote locations.
Secure remote access with identity-based authentication.

3. Role-Based Access Control (RBAC)

Use Case Scenario:

An organization uses Active Directory to assign roles to employees (e.g., Admin, HR, Developer). Zscaler reads these roles and enforces access policies accordingly. For example, HR staff can access HR systems, while developers can access development servers.

Output:

Users access only the resources permitted for their role.
Reduced risk of unauthorized data access.

4. Conditional Access Based on Device or Location

Use Case Scenario:

A user tries to log in from an unknown device or suspicious location. Zscaler checks identity and security policies through Microsoft Azure Active Directory and may require additional verification such as multi-factor authentication (MFA).

Output:

Additional security verification is triggered.
Potential threats or suspicious login attempts are blocked.

5. Secure Access to Cloud Applications

Use Case Scenario:

Employees access cloud services such as email or file storage through Zscaler. Authentication is handled by Okta, ensuring that only authorized users can reach these applications.

Output:

Secure and controlled access to cloud applications.
Centralized monitoring and logging of user activity.

STAGE 1

TITLE:

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

OVERVIEW:

Integrating Zscaler with Identity Providers (IdPs) such as Microsoft Azure Active Directory, Okta, and Active Directory enables secure and efficient user authentication and authorization for accessing organizational resources. In modern enterprise environments, where employees frequently access cloud applications and work remotely, traditional network-based security models are no longer sufficient. Identity-based security has become essential to ensure that only verified users can access sensitive data and applications.

Through this integration, Zscaler acts as a secure cloud gateway, while the Identity Provider manages and verifies user identities. When a user attempts to access an application, Zscaler redirects the authentication request to the configured IdP. The IdP validates the user's credentials and sends an authentication response back to Zscaler, allowing or denying access based on predefined security policies.

This integration supports Single Sign-On (SSO), enabling users to log in once and securely access multiple applications without repeatedly entering credentials. It also enables role-based access control, multi-factor authentication (MFA), and conditional access policies based on factors such as user identity, device type, and location.

Communication between Zscaler and the Identity Providers is typically established using secure authentication protocols like SAML (Security Assertion Markup Language) and OAuth. These protocols ensure secure data exchange and trusted authentication between systems.

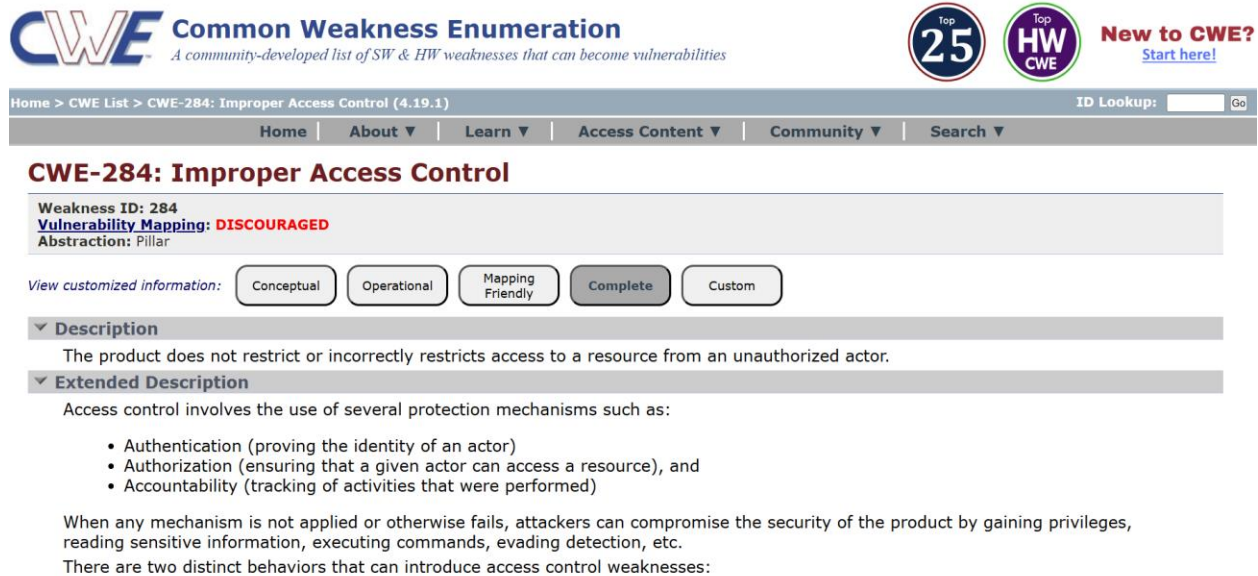
Overall, integrating Zscaler with identity providers strengthens security through a Zero Trust approach, improves user experience, simplifies identity management, and provides centralized control over authentication and access to enterprise applications.

List of Vulnerability Table

S NO	CATEGORY NAME	VULNERABILITY NAME	CWE/CVE - No
1	Broken Access Control	Improper Authorization / Privilege Escalation	CWE-284
2	Security Misconfiguration	Improper Configuration	CWE-16
3	Software Supply Chain Failures	Use of Components with Known Vulnerabilities	CWE-1104
4	Cryptographic Failures	Use of Weak or Broken Cryptography	CWE-327
5	Injection	SQL Injection / Command Injection	CWE-89
6	Insecure Design	Missing Security Controls in Design	CWE-657
7	Authentication Failures	Improper Authentication	CWE-287
8	Software or Data Integrity Failures	Code or Data Integrity Violation	CWE-353
9	Security Logging and Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Improper Error Handling	CWE-755

VULNERABILITY NAME: Broken Access Control

CWE: CWE-284



The screenshot shows the CWE website interface. At the top, the logo for "Common Weakness Enumeration" is displayed, along with a tagline: "A community-developed list of SW & HW weaknesses that can become vulnerabilities". To the right, there are two circular badges: "Top 25" and "Top HW CWE". A link "New to CWE? Start here!" is also present. Below the header, a navigation bar includes links for "Home", "About", "Learn", "Access Content", "Community", and "Search". The main heading is "CWE-284: Improper Access Control". Underneath, the "Weakness ID: 284" is shown, followed by "Vulnerability Mapping: DISCOURAGED" and "Abstraction: Pillar". A section titled "View customized information:" contains five buttons: "Conceptual", "Operational", "Mapping Friendly", "Complete", and "Custom". The "Description" section is expanded, showing the text: "The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor." The "Extended Description" section is also expanded, stating: "Access control involves the use of several protection mechanisms such as:" followed by a bulleted list: "Authentication (proving the identity of an actor)", "Authorization (ensuring that a given actor can access a resource), and", and "Accountability (tracking of activities that were performed)". Below this, it says: "When any mechanism is not applied or otherwise fails, attackers can compromise the security of the product by gaining privileges, reading sensitive information, executing commands, evading detection, etc." and "There are two distinct behaviors that can introduce access control weaknesses:".

Weakness ID: 284
Vulnerability Mapping: DISCOURAGED
Abstraction: Pillar

View customized information:

▼ **Description**
The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

▼ **Extended Description**
Access control involves the use of several protection mechanisms such as:

- Authentication (proving the identity of an actor)
- Authorization (ensuring that a given actor can access a resource), and
- Accountability (tracking of activities that were performed)

When any mechanism is not applied or otherwise fails, attackers can compromise the security of the product by gaining privileges, reading sensitive information, executing commands, evading detection, etc.
There are two distinct behaviors that can introduce access control weaknesses:

OWASP/SANS CATEGORY: OWASP A01 – Broken Access Control

DESCRIPTION: Broken Access Control occurs when an application fails to properly enforce user permissions. This allows unauthorized users to access restricted data, modify information, or perform actions beyond their intended privileges.

BUSINESS IMPACT: Unauthorized data exposure, privilege escalation, financial loss, and damage to organizational reputation.

VULNERABILITY NAME: Security Misconfiguration

CWE: CWE-16

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalization, and targeted advertising. To learn more, view the following link: [Privacy Policy](#)

Manage Preferences

Home > CWE List > CWE- Individual Dictionary Definition (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE CATEGORY: Configuration

Category ID: 16

Vulnerability Mapping: **PROHIBITED**

Summary

Weaknesses in this category are typically introduced during the configuration of the software.

Membership

Nature	Type	ID	Name
MemberOf	V	635	Weaknesses Originally Used by NVD from 2008 to 2016
MemberOf	C	933	OWASP Top Ten 2013 Category A5 - Security Misconfiguration
MemberOf	C	1032	OWASP Top Ten 2017 Category A6 - Security Misconfiguration
MemberOf	C	1349	OWASP Top Ten 2021 Category A05:2021 - Security Misconfiguration
MemberOf	C	1437	OWASP Top Ten 2025 Category A02:2025 - Security Misconfiguration

Vulnerability Mapping Notes

Usage: **PROHIBITED** (this CWE ID must not be used to map to real-world vulnerabilities)

Reason: Category

OWASP/SANS CATEGORY: OWASP A05 – Security Misconfiguration

DESCRIPTION: Security misconfiguration occurs when systems, servers, databases, or cloud services are incorrectly configured. This may include default credentials, open ports, or unnecessary services enabled.

BUSINESS IMPACT: Attackers may gain unauthorized access, leading to system compromise, service disruption, or exposure of sensitive data.

VULNERABILITY NAME: Software Supply Chain Failures

CWE: CWE-1104

**Common Weakness Enumeration**
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?
[Start here!](#)

Home > CWE List > CWE-1104: Use of Unmaintained Third Party Components (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

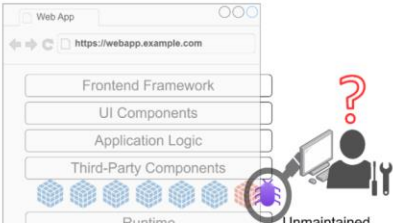
CWE-1104: Use of Unmaintained Third Party Components

Weakness ID: 1104
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information:

▼ Description

The product relies on third-party components that are not actively supported or maintained by the original developer or a trusted proxy for the original developer.



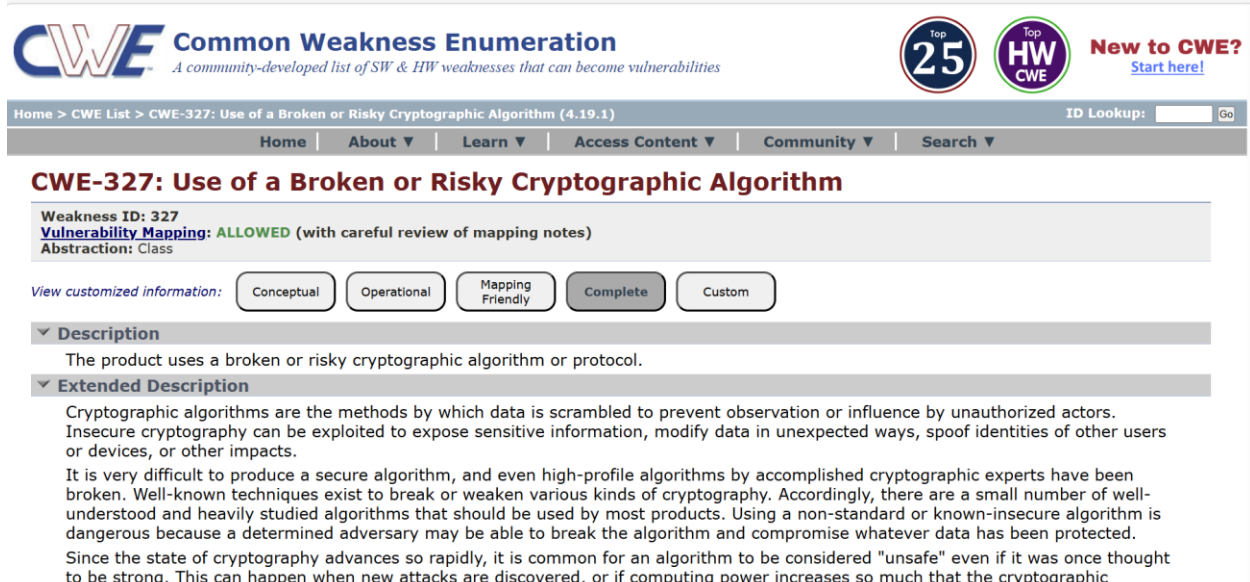
OWASP/SANS CATEGORY: OWASP A06 – Vulnerable and Outdated Components

DESCRIPTION: This vulnerability occurs when applications rely on third-party libraries or software components that contain known security vulnerabilities or are not regularly updated.

BUSINESS IMPACT: Attackers can exploit these vulnerabilities to compromise systems, steal data, or introduce malware.

VULNERABILITY NAME: Cryptographic Failures

CWE: CWE-327



CWE Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Home > CWE List > CWE-327: Use of a Broken or Risky Cryptographic Algorithm (4.19.1) ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

Weakness ID: 327
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information:

▼ **Description**
The product uses a broken or risky cryptographic algorithm or protocol.

▼ **Extended Description**
Cryptographic algorithms are the methods by which data is scrambled to prevent observation or influence by unauthorized actors. Insecure cryptography can be exploited to expose sensitive information, modify data in unexpected ways, spoof identities of other users or devices, or other impacts.

It is very difficult to produce a secure algorithm, and even high-profile algorithms by accomplished cryptographic experts have been broken. Well-known techniques exist to break or weaken various kinds of cryptography. Accordingly, there are a small number of well-understood and heavily studied algorithms that should be used by most products. Using a non-standard or known-insecure algorithm is dangerous because a determined adversary may be able to break the algorithm and compromise whatever data has been protected.

Since the state of cryptography advances so rapidly, it is common for an algorithm to be considered "unsafe" even if it was once thought to be strong. This can happen when new attacks are discovered, or if computing power increases so much that the cryptographic

OWASP/SANS CATEGORY: OWASP A02 – Cryptographic Failures

DESCRIPTION: Cryptographic failures occur when weak encryption algorithms, improper key management, or insecure protocols are used to protect sensitive information.

BUSINESS IMPACT: Exposure of confidential data such as passwords, financial information, and personal records, leading to privacy violations and regulatory penalties.

VULNERABILITY NAME: Injection

CWE: CWE-89

**Common Weakness Enumeration**
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?
[Start here!](#)

Home > CWE List > CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') (4.19.1)ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

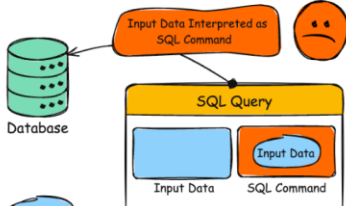
CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')

Weakness ID: 89
Vulnerability Mapping: **ALLOWED**
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

▼ Description

The product constructs all or part of an SQL command using externally-influenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component. Without sufficient removal or escaping of SQL syntax in user-controllable inputs, the



OWASP/SANS CATEGORY: OWASP A03 – Injection

DESCRIPTION: Injection vulnerabilities occur when untrusted user input is passed to an interpreter such as SQL, operating system commands, or LDAP queries without proper validation.

BUSINESS IMPACT: Data theft, database manipulation, system compromise, and potential loss of application control.

VULNERABILITY NAME: Insecure Design

CWE: CWE-657

**Common Weakness Enumeration**
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top
25

Top
HW
CWE

New to CWE?
[Start here!](#)

Home > CWE List > CWE-657: Violation of Secure Design Principles (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-657: Violation of Secure Design Principles

Weakness ID: 657
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information:

Conceptual

Operational

Mapping Friendly

Complete

Custom

▼ Description

The product violates well-established principles for secure design.

▼ Extended Description

This can introduce resultant weaknesses or make it easier for developers to introduce related weaknesses during implementation. Because code is centered around design, it can be resource-intensive to fix design problems.

▼ Common Consequences

Impact

Details

Other

Scope: Other

OWASP/SANS CATEGORY: OWASP A04 – Insecure Design

DESCRIPTION: Insecure design refers to flaws in the application architecture where proper security controls are not implemented during the design phase.

BUSINESS IMPACT: Long-term security risks, higher costs for remediation, and increased chances of successful cyberattacks.

VULNERABILITY NAME: Authentication Failures

CWE: CWE-287

 **Common Weakness Enumeration**
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?
[Start here!](#)

Home > CWE List > CWE-287: Improper Authentication (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

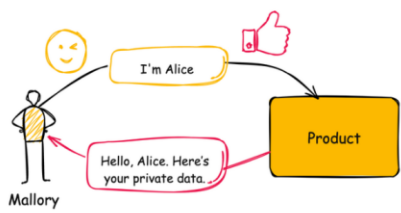
CWE-287: Improper Authentication

Weakness ID: 287
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual Operational Mapping Friendly Complete Custom

▼ Description

When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.



```
graph LR; Mallory((Mallory)) -- "I'm Alice" --> Product[Product]; Product -- "Hello, Alice. Here's your private data." --> Mallory;
```

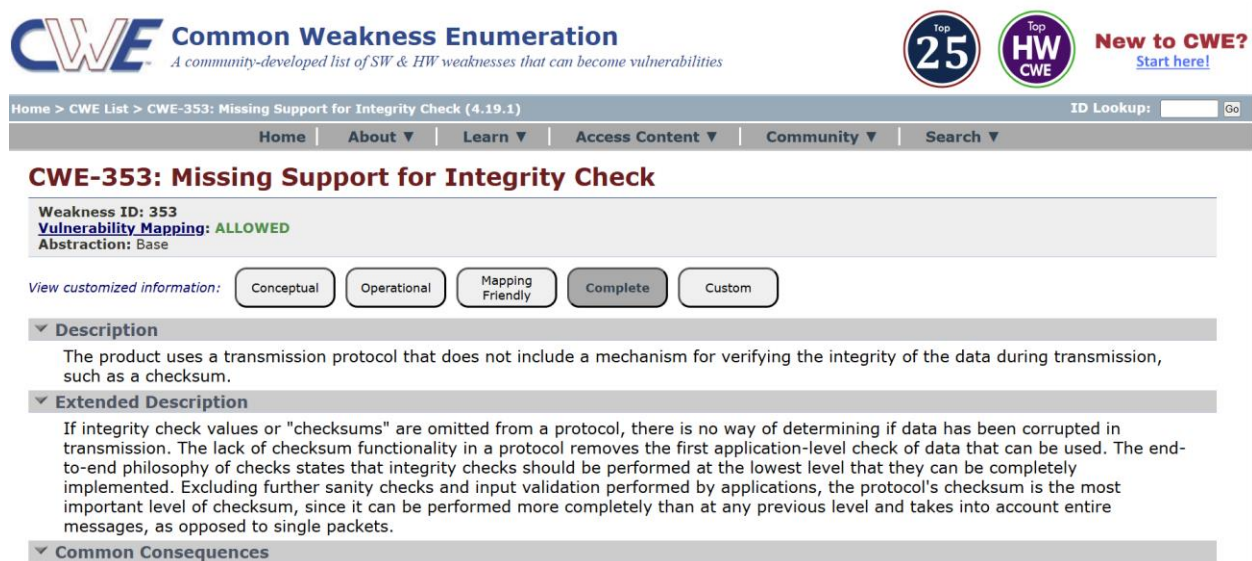
OWASP/SANS CATEGORY: OWASP A07 – Identification and Authentication Failures

DESCRIPTION: Authentication failures occur when login systems are poorly implemented, allowing attackers to bypass authentication mechanisms or perform account takeover attacks.

BUSINESS IMPACT: Unauthorized access to accounts, identity theft, and compromise of critical business systems.

VULNERABILITY NAME: Software or Data Integrity Failures

CWE: CWE-353



The screenshot shows the CWE-353 page on the Common Weakness Enumeration website. The header includes the CWE logo, the text "Common Weakness Enumeration" and "A community-developed list of SW & HW weaknesses that can become vulnerabilities", a "Top 25" badge, a "Top HW CWE" badge, and a "New to CWE? Start here!" link. The breadcrumb trail is "Home > CWE List > CWE-353: Missing Support for Integrity Check (4.19.1)". The navigation bar contains links for Home, About, Learn, Access Content, Community, and Search. The main heading is "CWE-353: Missing Support for Integrity Check". Below this, the "Weakness ID: 353" is shown, followed by "Vulnerability Mapping: ALLOWED" and "Abstraction: Base". There are five buttons for "View customized information": Conceptual, Operational, Mapping Friendly, Complete, and Custom. The "Description" section is expanded, showing the text: "The product uses a transmission protocol that does not include a mechanism for verifying the integrity of the data during transmission, such as a checksum." The "Extended Description" section is also expanded, showing the text: "If integrity check values or 'checksums' are omitted from a protocol, there is no way of determining if data has been corrupted in transmission. The lack of checksum functionality in a protocol removes the first application-level check of data that can be used. The end-to-end philosophy of checks states that integrity checks should be performed at the lowest level that they can be completely implemented. Excluding further sanity checks and input validation performed by applications, the protocol's checksum is the most important level of checksum, since it can be performed more completely than at any previous level and takes into account entire messages, as opposed to single packets." The "Common Consequences" section is also expanded, but its content is not visible.

OWASP/SANS CATEGORY: OWASP A08 – Software and Data Integrity Failures

DESCRIPTION: This vulnerability arises when software updates, code, or stored data are not properly validated, allowing attackers to modify or inject malicious code.

BUSINESS IMPACT: Malware infections, supply chain attacks, and loss of trust in the organization's software systems.

VULNERABILITY NAME: Security Logging and Alerting Failures

CWE: CWE-778

The screenshot shows the Common Weakness Enumeration (CWE) website. The header includes the CWE logo, the text "Common Weakness Enumeration" and "A community-developed list of SW & HW weaknesses that can become vulnerabilities". There are two circular badges: "Top 25" and "Top HW CWE". A link "New to CWE? Start here!" is also present. The breadcrumb trail reads "Home > CWE List > CWE-778: Insufficient Logging (4.19.1)". The navigation bar contains links: Home, About, Learn, Access Content, Community, and Search. The main heading is "CWE-778: Insufficient Logging". Below this, the "Weakness ID: 778" is shown, followed by "Vulnerability Mapping: ALLOWED" and "Abstraction: Base". There are five buttons for "View customized information": Conceptual, Operational, Mapping Friendly, Complete (selected), and Custom. The "Description" section states: "When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it." The "Extended Description" section states: "When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds. As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled." The "Common Consequences" section is partially visible.

OWASP/SANS CATEGORY: OWASP A09 – Security Logging and Monitoring Failures

DESCRIPTION: Occurs when systems lack proper logging and monitoring mechanisms to detect suspicious activities or attacks in real time.

BUSINESS IMPACT: Delayed detection of security incidents, prolonged breaches, and increased financial and reputational damage.

VULNERABILITY NAME: Mishandling of Exceptional Conditions

CWE: CWE-755

The screenshot shows the CWE-755 page on the Common Weakness Enumeration website. The page title is "CWE-755: Improper Handling of Exceptional Conditions (4.19.1)". The page includes a navigation bar with links to Home, About, Learn, Access Content, Community, and Search. The main content area displays the weakness ID, vulnerability mapping (DISCOURAGED), and abstraction (Class). It also features a "View customized information" section with buttons for Conceptual, Operational, Mapping Friendly, Complete, and Custom. The "Description" section states: "The product does not handle or incorrectly handles an exceptional condition." The "Common Consequences" section includes a table with columns for Impact and Details, showing "Other" for both. The "Relationships" section includes a table with columns for Nature, Type, ID, and Name, showing "Relevant to the view 'Research Concepts' (View-1000)".

CWE-755: Improper Handling of Exceptional Conditions

Weakness ID: 755
Vulnerability Mapping: **DISCOURAGED**
Abstraction: Class

View customized information:

▼ Description
The product does not handle or incorrectly handles an exceptional condition.

▼ Common Consequences

Impact	Details
Other	Scope: Other

▼ Relationships

▼ Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
--------	------	----	------

OWASP/SANS CATEGORY: SANS Top 25 – Improper Error Handling

DESCRIPTION: This vulnerability occurs when applications fail to properly handle errors or unexpected conditions, sometimes exposing sensitive system details to users.

BUSINESS IMPACT: Attackers may gain system information that can be used to launch further attacks or cause service disruptions.

STAGE 2

OVERVIEW

Tenable Nessus is a widely used vulnerability assessment and security scanning tool developed by Tenable. It helps organizations identify security vulnerabilities, configuration issues, and potential threats in their systems, networks, and applications. Nessus is commonly used by cybersecurity professionals to detect weaknesses before attackers can exploit them.

Nessus works by scanning systems such as servers, computers, network devices, and web applications to discover known vulnerabilities. It compares system configurations and software versions against a large database of known security issues such as Common Vulnerabilities and Exposures (CVE) and Common Weakness Enumeration (CWE). After scanning, the tool generates detailed reports showing the vulnerabilities, severity levels, and recommended remediation steps.

One of the key features of Nessus is its ability to perform automated vulnerability scanning. It supports different types of scans including network scans, web application scans, malware detection, and compliance checks. Nessus also provides risk scoring using the Common Vulnerability Scoring System (CVSS) to help organizations prioritize critical vulnerabilities.

Tenable Nessus is widely used in penetration testing, security auditing, compliance assessments, and vulnerability management programs. It helps organizations maintain strong cybersecurity by continuously monitoring systems and identifying weaknesses that could lead to cyberattacks.

TARGET WEBSITE : zero.webappsecurity.com

TARGET IP ADDRESS : 54.82.22.214

LIST OF VULNERABILITIES

S NO	VULNERABILITY NAME	SEVERITY	PLUGINS
1	SSL Version 2 and 3 Protocol Detection	Critical	20007
2	SSL / TLS Renegotiation Handshakes MiTM Plaintext Data Injection	Medium	42880
3	SSL Cipher Block Chaining Cipher Suites Supported	Info	70544
4	SSL Medium Strength Cipher Suites Supported	High	42873
5	SSL Resume With Different Cipher Issue	Info	58768

REPORT

VULNERABILITY 1

Vulnerability Name : SSL Version 2 and 3 Protocol Detection

Severity : Critical

Plugin : 20007

Port : 443

Description :

The remote server supports SSL version 2.0 and SSL version 3.0 protocols, which are outdated and contain several serious cryptographic vulnerabilities. These protocols use weak encryption mechanisms and insecure implementations that can be exploited by attackers.

SSLv2 and SSLv3 are vulnerable to multiple attacks such as padding oracle attacks, insecure session renegotiation, and downgrade attacks like POODLE (Padding Oracle On Downgraded Legacy Encryption). In such attacks, an attacker positioned between the client and server may force the communication to use these weaker protocols and potentially decrypt sensitive data transmitted over the network.

Because of these weaknesses, modern security standards such as NIST and PCI DSS no longer consider SSLv2 and SSLv3 acceptable for secure communications. The scan results

show that the server still allows connections using these outdated protocols and supports several weak cipher suites.

Solution :

To remediate this vulnerability, the following actions should be taken:

- Disable SSLv2 and SSLv3 protocols completely on the server.
- Configure the server to support only secure TLS versions such as TLS 1.2 or TLS 1.3.
- Remove weak or export-grade cipher suites from the server configuration.
- Update the server software, operating system, and SSL/TLS libraries to the latest versions.
- Follow industry security standards such as NIST guidelines and PCI DSS requirements for secure cryptographic configurations.

Business Impact :

If SSLv2 and SSLv3 remain enabled, attackers may exploit these weaknesses to perform man-in-the-middle (MitM) attacks or decrypt sensitive communications between the client and server. This can lead to:

- Exposure of confidential data such as login credentials and sensitive information
- Loss of data confidentiality and integrity
- Increased risk of cyberattacks and data breaches
- Non-compliance with industry security standards such as PCI DSS
- Damage to organizational reputation and customer trust

Vulnerability Name : SSL / TLS Renegotiation Handshakes MiTM Plaintext Data Injection

Severity : Medium

Plugin : 42880

Port : 443

Description :

The remote server supports SSL/TLS renegotiation in an insecure manner. During the TLS handshake process, the server allows a client to renegotiate the encrypted session without properly validating the original connection. Because of this weakness, an attacker positioned between the client and server (Man-in-the-Middle attacker) could inject malicious plaintext data into the beginning of the communication stream.

If the application assumes that both the original and renegotiated sessions belong to the same client, the injected data may be processed as legitimate input. This vulnerability is associated with CVE-2009-3555, which affects older implementations of SSL/TLS protocols.

The scan output shows that TLSv1 and SSLv3 support insecure renegotiation, making the service vulnerable to potential exploitation.

Solution :

To remediate this vulnerability:

- Apply security patches provided by the system or application vendor.
- Disable insecure SSL/TLS renegotiation on the server.
- Enable secure renegotiation as defined in RFC 5746.
- Upgrade to modern and secure TLS versions (TLS 1.2 or TLS 1.3).
- Disable outdated protocols such as SSLv3 and older TLS versions if they are not required.
- Regularly update server configurations and cryptographic libraries.

Business Impact :

If this vulnerability is exploited, attackers could perform Man-in-the-Middle (MitM) attacks and inject malicious content into encrypted communications. This may result in:

- Unauthorized modification of data during transmission
- Exposure of sensitive information
- Session hijacking or manipulation of application requests
- Loss of data integrity and trust in secure communications
- Potential security breaches affecting customers and business services

Vulnerability Name : SSL Cipher Block Chaining Cipher Suites Supported

Severity : Info

Plugin : 70544

Port : 443

Description :

The remote server supports SSL/TLS cipher suites that use Cipher Block Chaining (CBC) mode for encryption. While CBC mode is more secure than older encryption modes like Electronic Codebook (ECB), it can still be vulnerable to certain cryptographic attacks if not implemented correctly.

In some cases, CBC-based ciphers may expose systems to attacks such as padding oracle attacks or information leakage, especially when combined with outdated protocols or weak cryptographic configurations. The scan results indicate that the server supports multiple CBC-based cipher suites, including DES-CBC, 3DES-CBC, and AES-CBC, with some using low-strength encryption keys (40-bit or 56-bit).

Although this finding is categorized as informational, the presence of weak or outdated CBC cipher suites may reduce the overall security of encrypted communications.

Solution :

To improve security and reduce potential cryptographic risks, the following steps are recommended:

- Disable weak or export-grade cipher suites such as RC2-CBC, DES-CBC, and other low-strength ciphers.
- Configure the server to support modern and secure cipher suites only.
- Prefer AES-GCM or ChaCha20-Poly1305 cipher suites, which provide stronger authenticated encryption.
- Ensure that only strong TLS versions (TLS 1.2 or TLS 1.3) are enabled.
- Update the SSL/TLS configuration of the web server and cryptographic libraries regularly.

Business Impact :

If weak or outdated cipher suites remain enabled, attackers may attempt to exploit cryptographic weaknesses to compromise secure communications. Potential business impacts include:

- Reduced confidentiality of encrypted data
- Possibility of cryptographic attacks leading to information leakage
- Increased risk of security compliance violations
- Reduced trust in the organization's secure communication infrastructure

Vulnerability Name : SSL Medium Strength Cipher Suites Supported

Severity : High

Plugin : 42873

Port : 443

Description :

The remote server supports medium-strength SSL/TLS cipher suites, specifically those that use the 3DES (Triple DES) encryption algorithm. According to the scan results, the server allows cipher suites such as DES-CBC3-SHA, EDH-RSA-DES-CBC3-SHA, and DES-CBC3-MD5.

These cipher suites use 64-bit block ciphers, which are vulnerable to the SWEET32 attack. In this attack, an attacker who can observe a large amount of encrypted network traffic may exploit birthday-bound collisions in 64-bit block ciphers to recover portions of the encrypted data.

Although these ciphers were previously considered secure, modern security standards recommend disabling them because stronger encryption algorithms are now available. The presence of these cipher suites weakens the overall security of encrypted communications.

Solution :

To mitigate this vulnerability, the following actions are recommended:

- Disable 3DES and other medium-strength cipher suites in the SSL/TLS configuration.
- Configure the server to support strong cipher suites only, such as AES-GCM or ChaCha20-Poly1305.
- Ensure the server supports modern TLS versions (TLS 1.2 or TLS 1.3).
- Update server software and cryptographic libraries regularly to maintain secure configurations.
- Review SSL/TLS configuration settings and remove outdated encryption algorithms.

Business Impact :

If medium-strength cipher suites remain enabled, attackers may exploit cryptographic weaknesses such as the SWEET32 attack to partially recover encrypted data. This could lead to:

- Exposure of sensitive information transmitted over encrypted connections
- Reduced confidentiality of secure communications
- Increased risk of data interception during network traffic monitoring
- Potential non-compliance with modern security standards and regulations

Vulnerability Name : SSL Resume With Different Cipher Issue

Severity : Info

Plugin : 58768

Port : 443

Description :

The SSL/TLS implementation on the remote server allows a session to resume with a different cipher suite than the one originally negotiated during the initial SSL handshake. Normally, when an SSL session is resumed, the server should use the same cipher that was used during the original connection.

However, the scan indicates that the server resumed a TLS session using a weaker cipher (DES-CBC-SHA) instead of the stronger cipher (AES-256-CBC-SHA) that was initially negotiated. This behavior can allow an attacker who is able to observe network traffic to manipulate the session cache and force the server to resume the session using a weaker encryption algorithm.

Although this vulnerability is categorized as informational, it indicates a weak SSL/TLS configuration that may reduce the overall security of encrypted communications.

Solution :

To mitigate this issue, the following steps are recommended:

- Configure the server to use the same cipher suite during session resumption as used during the original handshake.
- Disable weak cipher suites, especially those using DES encryption.
- Enable only strong cipher suites, such as AES-GCM or ChaCha20-Poly1305.
- Upgrade the server's SSL/TLS libraries and software to the latest secure versions.
- Enforce strong SSL/TLS security configurations and follow modern cryptographic best practices.

Business Impact :

If this issue is not addressed, attackers may exploit session resumption behavior to downgrade encryption strength during SSL/TLS communication. This could lead to:

- Reduced security of encrypted sessions
- Potential exposure of sensitive information
- Increased risk of cryptographic attacks or traffic interception
- Weak overall SSL/TLS security posture for the organization

STAGE 3

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

1. Overview of Zscaler and Identity Providers

Zscaler is a cloud-based cybersecurity platform that provides secure access to internet and internal applications without relying on traditional network security appliances such as VPNs and firewalls. It operates on a Zero Trust security model, where every user and device must be verified before access is granted. Zscaler services such as Zscaler Internet Access (ZIA) and Zscaler Private Access (ZPA) help organizations protect users from cyber threats and securely connect them to applications.

Identity Providers (IdPs) such as Microsoft Azure Active Directory, Okta, and Active Directory are systems responsible for managing digital identities and authenticating users. They store user credentials, maintain identity attributes, and verify login requests. Integrating Zscaler with these IdPs enables organizations to authenticate users through a centralized identity management system. This integration ensures that only verified users are allowed to access network resources, improving security and simplifying identity management.

2. Authentication Methods (SAML and OAuth)

Authentication between Zscaler and Identity Providers is typically achieved using secure authentication protocols such as Security Assertion Markup Language (SAML) and OAuth/OpenID Connect. These protocols enable secure communication between the service provider (Zscaler) and the Identity Provider.

SAML is an XML-based authentication protocol that allows the IdP to authenticate the user and send an authentication assertion to Zscaler. When a user attempts to access a resource protected by Zscaler, the user is redirected to the Identity Provider for authentication. Once verified, the IdP sends a secure token back to Zscaler confirming the user's identity.

OAuth and OpenID Connect are modern authentication frameworks that provide secure delegated access. OAuth allows applications to access resources on behalf of a user without sharing credentials, while OpenID Connect adds identity verification capabilities. These protocols ensure that authentication is handled securely and efficiently, reducing the risk of credential exposure and unauthorized access.

3. Single Sign-On (SSO) Implementation

Single Sign-On (SSO) is an authentication mechanism that allows users to log in once and gain access to multiple applications and services without repeatedly entering their credentials. When Zscaler is integrated with Identity Providers like Azure AD or Okta, SSO allows users to authenticate through the IdP and automatically access resources protected by Zscaler.

For example, when an employee logs into their corporate account through the Identity Provider, they are automatically authenticated to access internet services, internal applications, and cloud resources managed by Zscaler. This improves user experience by reducing login interruptions and password fatigue.

In addition to convenience, SSO improves security because authentication is handled by a centralized system. Security policies such as password complexity, login monitoring, and conditional access can be applied at the Identity Provider level. This ensures consistent and secure authentication across all connected applications.

4. User Identity Mapping and Directory Synchronization

User identity mapping is an important component of Zscaler and IdP integration. Identity Providers maintain directories that store user information such as usernames, email addresses, departments, and group memberships. When integrated with Zscaler, this information is synchronized so that Zscaler can apply security policies based on user identity.

Directory synchronization ensures that user accounts, groups, and attributes are automatically updated in Zscaler whenever changes occur in the Identity Provider. For instance, if a new employee is added to the company's directory or moved to a different department, the update is automatically reflected in Zscaler policies.

This synchronization eliminates the need for manual user management in multiple systems and reduces administrative workload. It also ensures that security policies remain accurate and consistent across the organization. By linking identity data with access policies, organizations can implement more precise and dynamic security controls.

5. Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) is a security model that restricts system access based on the roles assigned to users within an organization. When Zscaler is integrated with Identity Providers, roles and group memberships defined in the IdP are used to determine user access permissions.

For example, employees in the finance department may have access to financial applications, while IT administrators may have broader access to system management tools. Zscaler uses the role information received from the Identity Provider to enforce these access policies.

RBAC helps organizations implement the principle of least privilege, where users are granted only the permissions necessary to perform their job functions. This reduces the risk of accidental data exposure and limits the potential impact of compromised accounts. By integrating RBAC with Zscaler, organizations can enforce granular access policies across internet traffic, cloud applications, and private resources.

6. Multi-Factor Authentication (MFA) Support

Multi-Factor Authentication (MFA) adds an extra layer of security to the authentication process by requiring users to provide multiple forms of verification. In addition to entering a password, users may need to verify their identity using a one-time password (OTP), a mobile authentication app, biometric verification, or a hardware security key.

Identity Providers such as Azure AD and Okta provide built-in MFA capabilities. When integrated with Zscaler, MFA can be enforced during the authentication process before users are granted access to network resources.

This additional security measure significantly reduces the risk of unauthorized access caused by stolen or weak passwords. Even if an attacker obtains a user's credentials, they will still need the second authentication factor to gain access. MFA is particularly important for protecting sensitive applications and remote access environments.

7. Policy Enforcement Based on User Identity

After authentication is successfully completed through the Identity Provider, Zscaler applies security policies based on the user's identity and associated attributes. These policies can control various aspects of user activity, including internet access, application usage, and data protection.

For instance, employees in certain departments may be restricted from accessing social media websites during working hours, while management staff may have broader internet access privileges. Zscaler can also apply different policies depending on factors such as user role, device type, location, or risk level.

Identity-based policy enforcement ensures that security controls are personalized and context-aware rather than relying solely on network location. This approach aligns with modern Zero Trust security principles, where every access request is verified and evaluated before permission is granted.

8. Monitoring, Logging, and Compliance

Monitoring and logging play a critical role in maintaining the security and compliance of an organization's IT environment. When Zscaler is integrated with Identity Providers, detailed logs of user authentication and access activities are generated.

These logs include information such as login attempts, authentication success or failure, accessed applications, and policy enforcement actions. Security administrators can analyze this data to detect suspicious behavior, investigate potential security incidents, and respond to threats quickly.

In addition, the collected logs can be used to generate compliance reports for regulatory requirements such as data protection laws and industry standards. Organizations can demonstrate that proper authentication controls, access restrictions, and monitoring mechanisms are in place to protect sensitive information.

CONCLUSION

This project focused on identifying and analyzing security vulnerabilities in a web application environment through systematic security assessment techniques.

In the initial stage, information gathering and reconnaissance were performed to understand the target system, its services, and network configuration. This stage helped in identifying the target host and preparing the environment for further security testing.

In the second stage, vulnerability assessment was conducted using security scanning tools. Several vulnerabilities related to SSL/TLS configurations, cipher suite weaknesses, and outdated security protocols were identified. These findings demonstrated how improper security configurations and the use of outdated encryption mechanisms can expose systems to potential threats such as man-in-the-middle attacks, data interception, and cryptographic weaknesses.

In the final stage, the detected vulnerabilities were analyzed and appropriate remediation measures were suggested. Recommended solutions included disabling insecure protocols, removing weak cipher suites, enabling stronger encryption standards, and applying proper security configurations. These steps help strengthen the security posture of the system and reduce the risk of cyberattacks.

FUTURE ENHANCEMENTS

Stage 1 – Information Gathering and Reconnaissance:

In future improvements, the reconnaissance stage can be enhanced by integrating advanced automated tools that collect detailed information about the target system, including network topology, open ports, services, and system configurations. Automation can help reduce manual effort and improve the speed and accuracy of data collection. Additionally, incorporating advanced network mapping and monitoring tools can provide deeper insights into the target environment.

Stage 2 – Vulnerability Scanning and Analysis:

This stage can be improved by integrating multiple vulnerability scanning tools and advanced security frameworks to increase detection accuracy. Future enhancements may include the use of artificial intelligence and machine learning techniques to identify new or unknown vulnerabilities and prioritize risks based on severity and exploitability. Continuous or scheduled scanning can also be implemented to detect newly emerging threats in real time.

Stage 3 – Remediation and Security Improvement:

Future developments in this stage can focus on automated remediation techniques that provide configuration fixes and patch recommendations for identified vulnerabilities. Integration with security monitoring systems and dashboards can help track vulnerability status and remediation progress effectively. Additionally, implementing continuous security monitoring and compliance checks can help organizations maintain a strong security posture and prevent future security incidents.

TOPICS EXPLORED

Overview of Zscaler and Identity Providers, Authentication Methods, Single Sign-On (SSO) Implementation, User Identity Mapping and Directory Synchronization, Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA) Support, Policy Enforcement Based on User Identity, Monitoring Logging and Compliance, Cybersecurity Vulnerabilities and Assessment, Broken Access Control, Security Misconfiguration, Software Supply Chain Failures, Cryptographic Failures, Injection, Insecure Design, Authentication Failures, Software or Data Integrity Failures, Security Logging and Alerting Failures, Mishandling of Exceptional Conditions, Tenable Nessus Scanning, SSL/TLS Specific Vulnerabilities, Outdated Protocol Detection (SSL Version 2 and 3), SSL/TLS Renegotiation Handshakes, Weak Cipher Suites (CBC Mode 3DES SWEET32), SSL Session Resumption with Different Ciphers.

TOOLS EXPLORED

- whatismyipaddress.com
- Medium
- Tenable Nessus
- OWASP 2025